

Data_Security_P IPL

Technical Standard

保险公司 技术开发部
内部文档 · 仅供授权人员查阅

Contents

1. Overview
2. Personal Information Classification
 - 2.1 Insurance Industry Data Classification
 - 2.2 Processing Principles
3. Technical Protection
 - 3.1 Encryption
 - 3.2 Data Masking
 - 3.3 Access Control
4. PIA Triggers
5. Data Lifecycle
6. User Rights Response

Data Security & Personal Information Protection Standard

1. Overview

This document defines technical standards for data security and personal information protection on the insurance technology platform, implementing the Personal Information Protection Law (PIPL), Data Security Law, and financial industry requirements. It applies to all application systems that process personal data.

2. Personal Information Classification

2.1 Insurance Industry Data Classification

Level	Definition	Examples	Protection
L4 Extremely Sensitive	Severe personal/property damage	Bank card + PIN, biometrics	Encrypted, audited access
L3 Highly Sensitive	Significant risk	ID number, phone, address, health info	Encrypted, minimized, masked
L2 Generally Sensitive	General risk	Name, email, policy info	Internal isolation, need-to-know
L1 Non-sensitive	Low risk	Anonymized data, statistics	Basic access control

2.2 Processing Principles

- **Lawful, Fair, Necessary:** Collect only what's business-essential
- **Notice & Consent:** Inform purpose, method, scope before collection
- **Purpose Limitation:** Use only for stated purposes
- **Data Minimization:** Minimum data necessary for business
- **Accuracy:** Provide channels for correction
- **Storage Limitation:** Delete or anonymize beyond retention

3. Technical Protection

3.1 Encryption

Scenario	Solution	Algorithm
Transport	Full HTTPS TLS 1.3	TLS 1.3
Database	TDE	AES-256
Field-level	Application-layer encryption	AES-256-GCM
Backup	Storage encryption	AES-256
Key Management	Centralized KMS	90-day rotation

3.2 Data Masking

Type	Method	Original	Masked
Name	First char + *	Zhang Sanfeng	Z***
Phone	Middle 4 hidden	13812345678	138****5678
ID Number	First 6 + last 4	110101199001011234	110101****1234
Bank Card	First 4 + last 4	6222021234567890	6222****7890

Masking rules centrally configured, systems use masking SDK instead of implementing their own.

3.3 Access Control

- SSO + MFA (mandatory for admin consoles)
- RBAC/ABAC fine-grained permissions
- DB whitelist IP + proxy, no direct connections
- Batch export requires approval, encrypted files
- JWT + Scope for APIs, additional signing for sensitive endpoints
- Full audit logging

4. PIA Triggers

Initiate PIA when:

1. Processing sensitive personal information
2. Automated decision-making (UW, claims)
3. Outsourced processing
4. Cross-border data transfer
5. Large-scale processing (>1M records)

5. Data Lifecycle

Phase	Requirement	Implementation
Collection	Minimization, consent	Form review, tracking approval
Storage	Graded encryption	Encryption SDK, KMS
Use	Masking, authorization	Masking middleware, permission platform
Transmission	Encrypted channel	TLS, SM2/SM4
Sharing	Contract + audit	Data sharing platform
Destruction	Secure deletion	Physical overwrite/marking
Backup	Encryption	Encrypted backup storage

6. User Rights Response

Right	Implementation	SLA
Right to Know	Privacy policy, data map	-
Withdraw Consent	Withdrawal mechanism	T+0
Right to Access	Customer center API	T+0

Right	Implementation	SLA
Right to Correct	Profile edit	T+0
Right to Delete	Account deletion workflow	T+15
Right to Portability	Structured data export	T+7